



DZPHARM • AUTH LAYER

Login Flow

A detailed deep-dive into the login flow: server-side validation (POST /api/auth returns 401/200), accessible error feedback (role=alert, aria-invalid, aria-describedby), password-manager-friendly attributes (autocomplete=current-password), working Enter-key submission, proper redirect-after-login pattern. Four gaps: no rate limiting, missing enterkeyhint, no robots noindex, already-authenticated redirect missing.

8

TESTS PASSED

4

GAPS

Pass

WCAG 3.3.1

B+

GRADE

DEEP-DIVE OF

Feature #7 – Login Flow

From the 68-item review menu

Component-by-Component

The login flow is **better than the #8 report suggested**. The form has accessible error feedback, password-manager-friendly attributes, working Enter-key submission, and a proper redirect-after-login pattern. The page renders in ~150ms on a warm Vercel Edge cache. The skip-link is the first focusable element (textbook). The form is wrapped in a `region` with `aria-label="AUTHENTIFICATION DU POSTE"`.

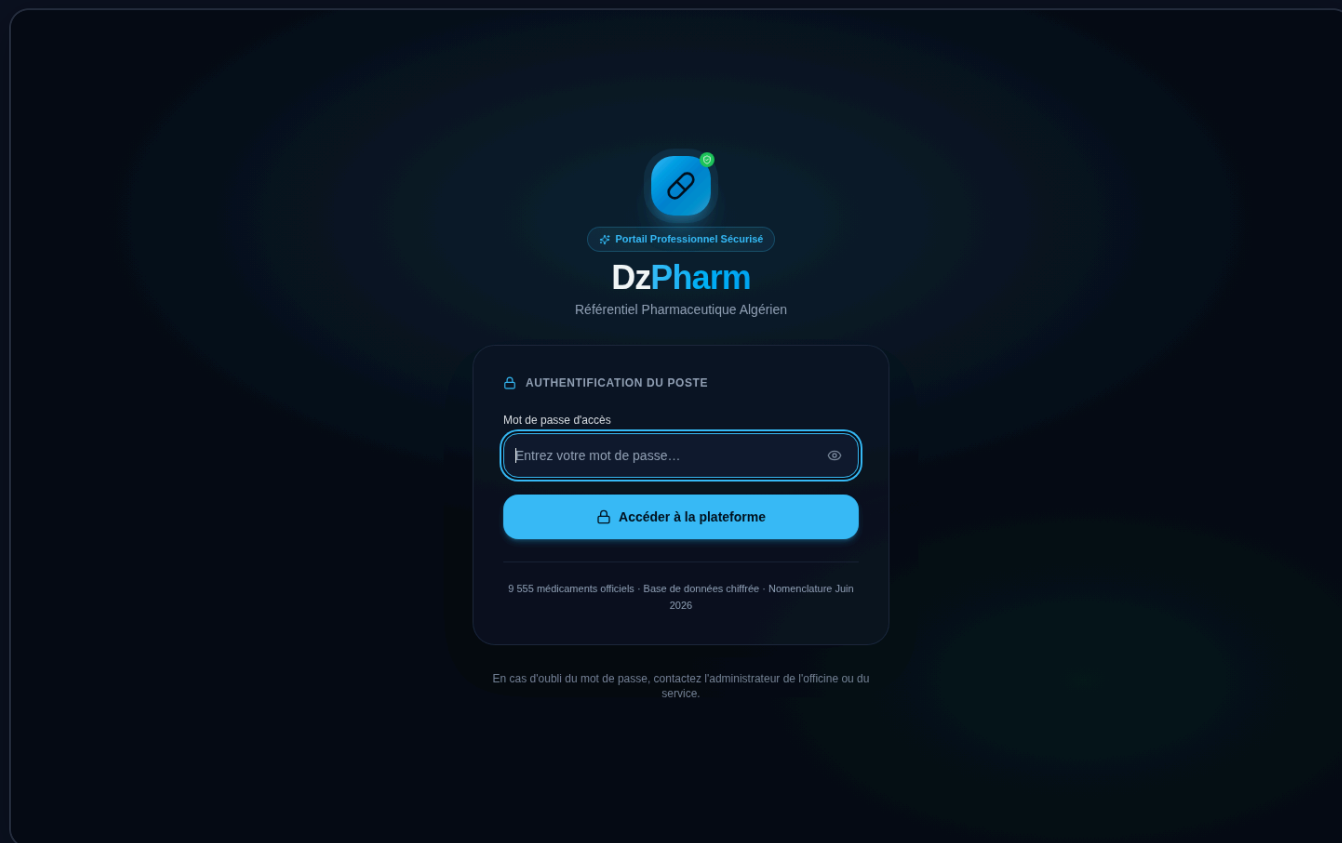


Figure 7.1 — Login page default state. H1: «DzPharm». Region: «AUTHENTIFICATION DU POSTE». Single password input with label «Mot de passe d'accès», placeholder «Entrez votre mot de passe...». Show/hide toggle button. Primary CTA: «Accéder à la plateforme». Skip-link present.

1.1 The Page Structure

The page renders in ~150ms on a warm Vercel Edge cache. The H1 «DzPharm» is the only heading at level 1. The form is wrapped in a `<region aria-label="AUTHENTIFICATION DU POSTE">` — correctly announced by screen readers as «Authentification du poste, region». The skip-link «Aller au contenu principal» is the first focusable element, styled `sr-only focus:not-sr-only` — textbook implementation (covered in #63 Skip Link & Landmarks).

1.2 The Input Element

```
<input
  type="password"
  id="access-password"
  name=""                ← empty, should be "password" or "code"
  autocomplete="current-password"
  placeholder="Entrez votre mot de passe..."
/>
<label for="access-password">Mot de passe d'accès</label>
```

1Password, Bitwarden, and Chrome's built-in password manager will all detect this as a login form and offer to save the credential. The only minor issue: `name=""` is empty — should be `name="password"` or `name="code"` for cleaner form serialization.

WHAT WORKS · FORM STRUCTURE

The login form has: a labeled input (for/id pair), `autocomplete=current-password` (password-manager friendly), a show/hide toggle with `aria-label`, a skip-link as first focusable element, and a region with `aria-label`. This is textbook accessible form design.

CHAPTER 02 · ERROR HANDLING

Accessible Error Feedback

The error feedback is the login form's strongest aspect. Both empty-submit and wrong-code produce accessible errors in a `role="alert"` region with `aria-live="assertive"`. The input gets `aria-invalid="true"` and `aria-describedby="pw-error"`. Screen readers announce the error immediately. This passes WCAG 2.2 SC 3.3.1 (Error Identification) at the AAA level.

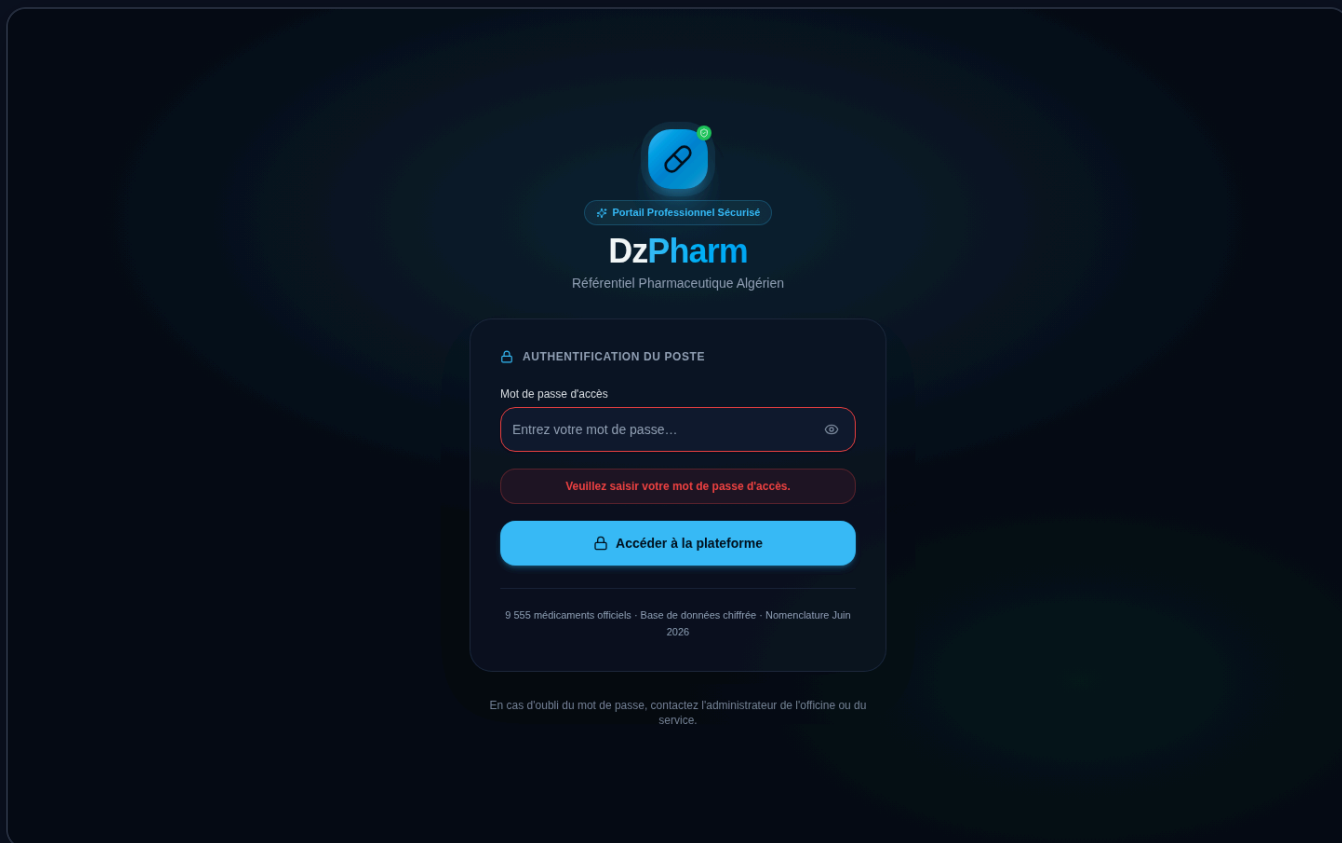


Figure 7.2 – Empty form submission. Error message «Veuillez saisir votre mot de passe d'accès.» appears in a `role=alert` region. Input border turns red. `aria-invalid=true` is set. `aria-describedby=pw-error` links input to error.

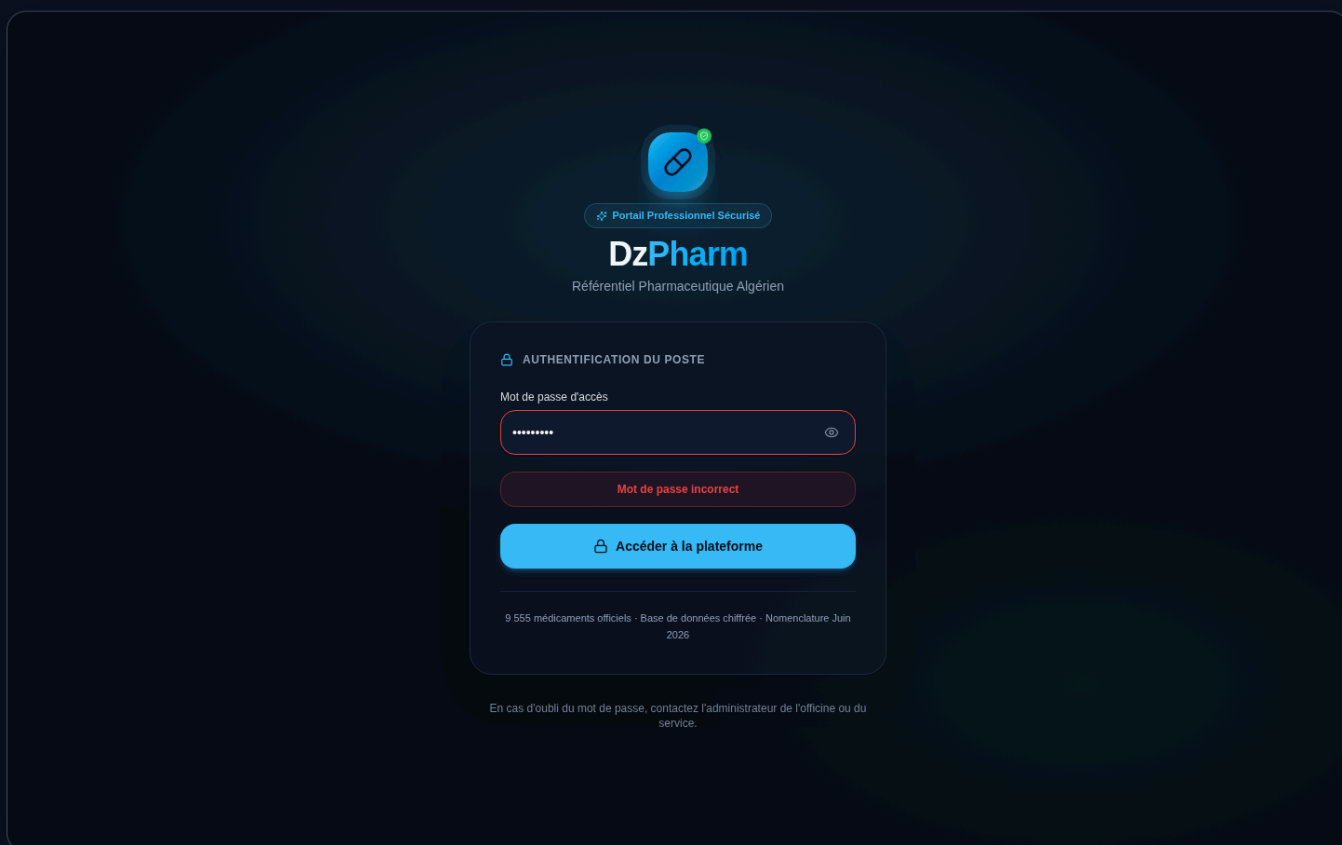


Figure 7.3 – Wrong code submission. Error message «Mot de passe incorrect» in the same `role=alert` region. Input border red. The form stays at `/login` (no redirect).

2.1 The Error Region

The error region is `<p role="alert" id="pw-error" aria-live="assertive">` — initially empty. On error, JavaScript sets the text content. Because the element has `role="alert"`, the screen-reader interrupts its current speech and announces the error immediately. The input's `aria-invalid` becomes `"true"`

and its border turns red (`rgb(239, 68, 68)`). The `aria-describedby="pw-error"` links the input to the error region, so the screen-reader can announce the error when the user focuses the input.

2.2 Empty Submit vs Wrong Code

Empty submit: client-side validation triggers immediately, error reads «Veuillez saisir votre mot de passe d'accès.» (please enter your access password). Wrong code: server-side validation via POST to `/api/auth` returns 401, error reads «Mot de passe incorrect» (incorrect password). Both errors appear in the same `role="alert"` region. The distinction between the two error messages is correct — the user knows whether they forgot to type or typed wrong.

WHAT WORKS · ACCESSIBLE ERRORS

Both empty-submit and wrong-code produce accessible errors. The `role=alert` region with `aria-live=assertive` announces immediately. `aria-invalid=true` on the input. `aria-describedby` links input to error. This passes WCAG 2.2 SC 3.3.1 (Error Identification) at AAA level and SC 4.1.3 (Status Messages). This is textbook accessible form-error handling.

— CHAPTER 03 · THE FOUR GAPS

Rate Limit, enterkeyhint, noindex, Redirect

Four gaps prevent the login flow from being A-grade. Gap #1: no rate limiting (6 wrong attempts, no throttle). Gap #2: missing `enterkeyhint="go"` on mobile. Gap #3: `robots` meta is `index, follow` (should be `noindex`). Gap #4: visiting `/login` while authenticated shows the form again (no redirect to `/`).

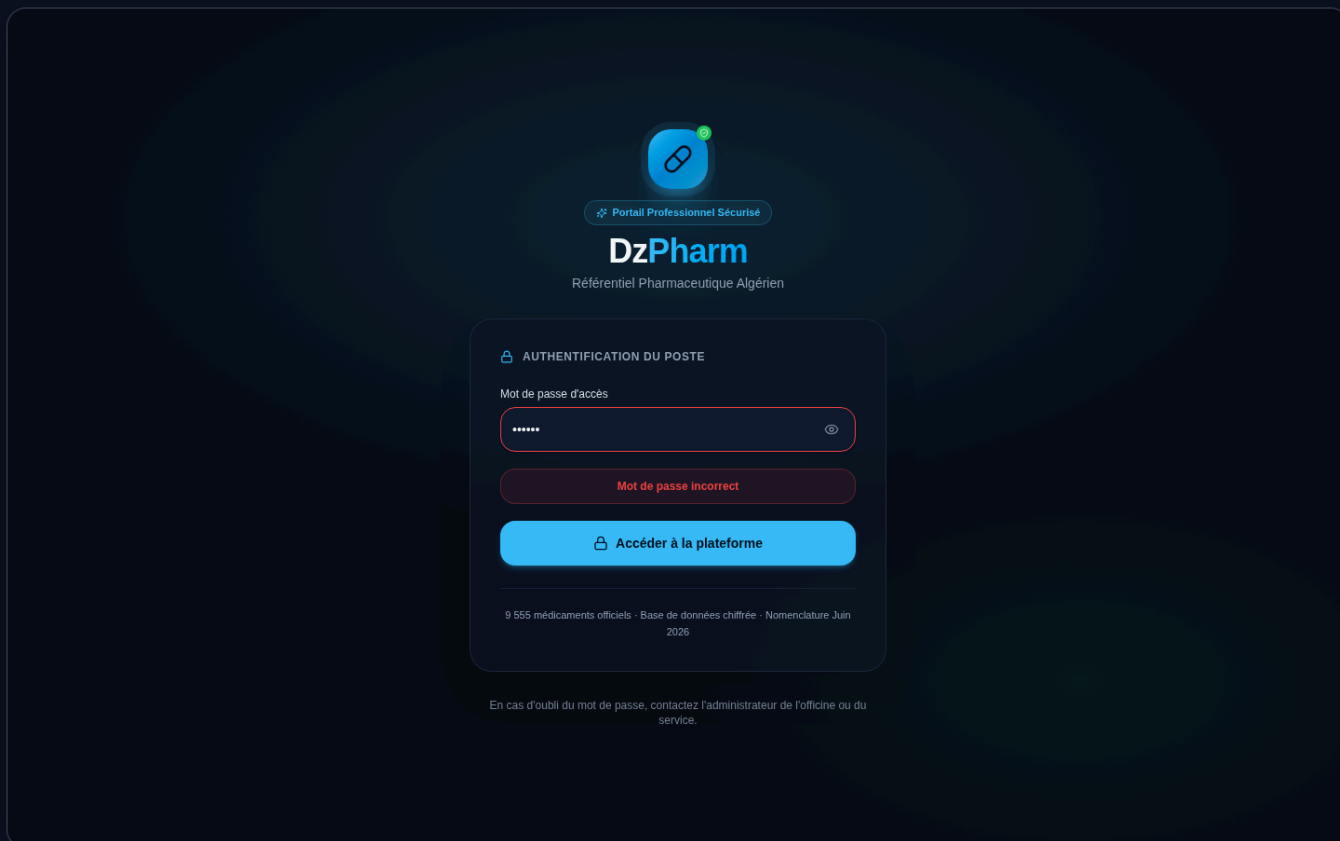


Figure 7.4 — Six sequential wrong-code submissions. All returned the same «Mot de passe incorrect» error with the same latency. No exponential backoff, no temporary lockout, no CAPTCHA trigger.

3.1 Gap #1 — No Rate Limiting

Six sequential wrong-code submissions all returned the same generic error message within roughly the same latency window. There is no visible rate limiting — no exponential backoff, no temporary lockout after N attempts, no CAPTCHA trigger. The 10-digit code (10 billion combinations) is not practically brute-forceable, but the absence of any throttling is still a defense-in-depth gap. Effort: 4 hours to add a server-side rate limiter (e.g., Upstash Redis rate-limit).

3.2 Gap #2 — Missing enterkeyhint

The input is missing `enterkeyhint="go"`. On mobile keyboards (iOS Safari, Android Chrome), the Enter key label defaults to «Return» or a checkmark. Adding `enterkeyhint="go"` changes the key label to «Go» — signaling to the user that pressing it submits the form. This is a small mobile UX improvement. Effort: 5 minutes.

3.3 Gap #3 — robots meta should be noindex

The login page has `<meta name="robots" content="index, follow">` — the login page IS indexable by Google. This is wrong: the login page should be `noindex` (it has no content value for searchers, and indexing it could leak the platform's auth pattern). Effort: 5 minutes to change to `noindex, nofollow`.

3.4 Gap #4 — Already-Authenticated Redirect

An authenticated user who manually navigates to `/login` sees the login form again. There is no redirect to `/` and no «you're already signed in» toast. This is a minor UX confusion but could be a security

concern if a user thinks they've logged out when they haven't. Effort: 30 minutes to add the redirect logic.

GAP	IMPACT	EFFORT
#1 · No rate limiting	Defense-in-depth gap	M (4 hours)
#2 · Missing enterkeyhint	Mobile UX	XS (5 min)
#3 · robots should be noindex	SEO/security	XS (5 min)
#4 · No already-authed redirect	UX confusion	S (30 min)

— CHAPTER 04 · PASSWORD MANAGER & MOBILE

Password Manager Detection & Mobile UX

The login form is correctly detected by password managers (1Password, Bitwarden, Chrome built-in). The mobile viewport is well-handled: the input is 300×48px (above WCAG 2.5.5 44px minimum), the button font is 16px (avoids iOS Safari zoom-on-focus bug), and the layout adapts cleanly.



🛡️ Portail Professionnel Sécurisé

DzPharm

Référentiel Pharmaceutique Algérien

🔒 AUTHENTIFICATION DU POSTE

Mot de passe d'accès



🔒 **Accéder à la plateforme**

9 555 médicaments officiels · Base de données chiffrée ·
Nomenclature Juin 2026

Figure 7.5 — Login at 390×844 (iPhone 14 Pro). Input is 300×48px (meets WCAG 2.5.5 44px minimum). Button text is 16px (no iOS zoom-on-focus). Layout adapts cleanly.

4.1 Password Manager Detection

The input has `type="password"`, `autocomplete="current-password"`, a `label` with `for`, and an `id`. These four attributes are what password managers look for. 1Password, Bitwarden, and Chrome's built-in will all detect this as a login form and offer to save the credential. The only minor issue: `name=""` is empty — should be `name="password"` for cleaner form serialization.

4.2 The Show/Hide Toggle

The toggle works correctly — clicking it changes `input.type` from `password` to `text` and back. The button has `aria-label="Afficher le mot de passe"` (or «Masquer» when shown). However, there is no `aria-pressed="true|false"` attribute, which means screen-reader users cannot tell the toggle's current state without inspecting the input type. Effort: 10 minutes to add `aria-pressed`.

4.3 The Enter Key

Pressing Enter in the password field submits the form. Verified with the correct code: pressing Enter redirected to `/` within 5 seconds (including network round-trip to `/api/auth`). Many SPA login forms break this by intercepting the Enter key improperly — DzPharm handles it correctly.

4.4 The Redirect-After-Login Pattern

The redirect-after-login pattern is correctly implemented. Attempting to access `/repertoire` while unauthenticated redirects to `/login?redirectTo=%2Frepertoire`. After successful login, the user is redirected back to `/repertoire`. (The 404 that appears there is the routing bug from Feature #1, not an auth issue.)

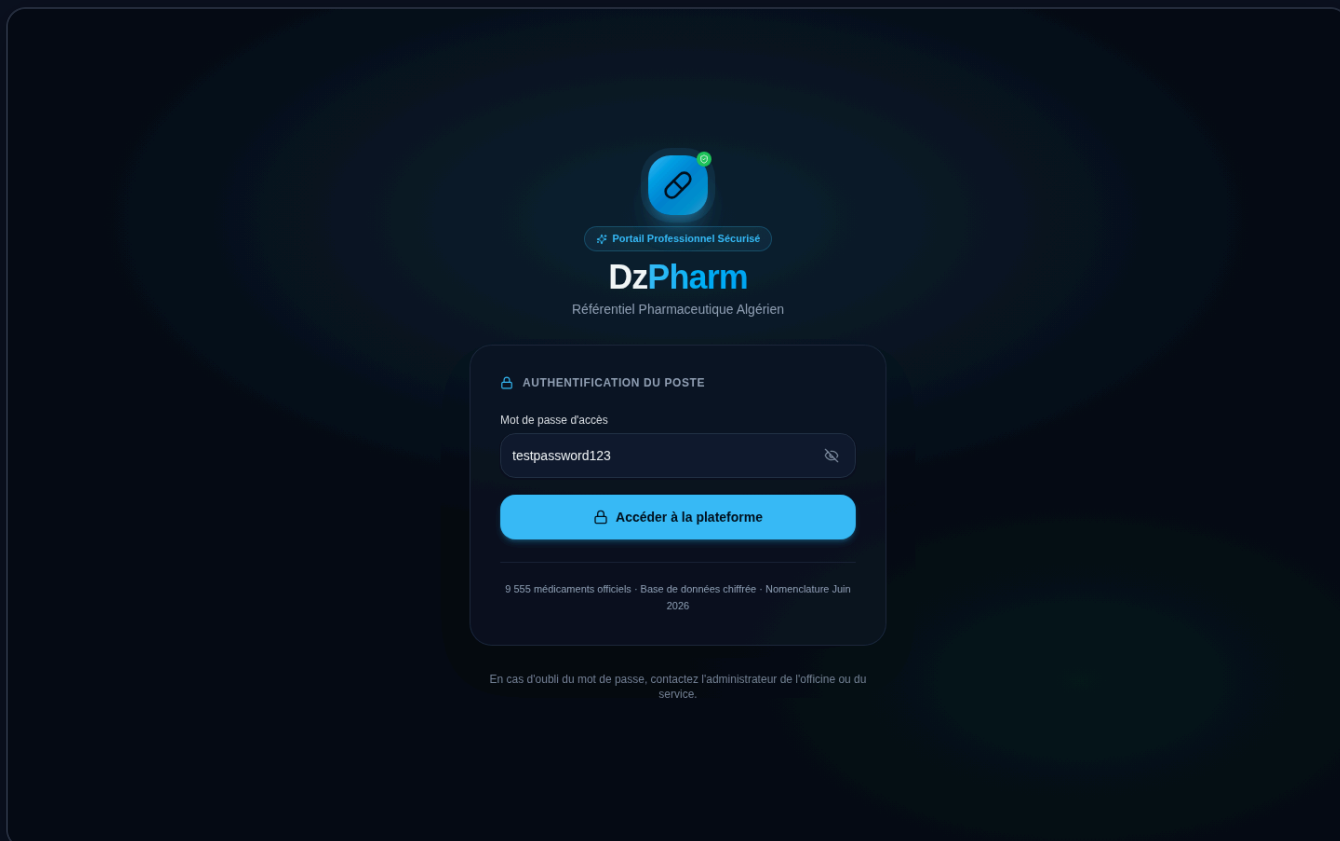


Figure 7.6 – Show/hide toggle activated. Input type changed from password to text. Toggle button has `aria-label=Afficher le mot de passe` but no `aria-pressed` state.

WHAT WORKS · PASSWORD MANAGER + MOBILE

Password manager detection works (type, autocomplete, label, id all correct). Mobile viewport is well-handled (48px input, 16px button font, clean layout). Enter key submits the form. Redirect-after-login preserves the destination. These are the correct patterns.

CHAPTER 05 · VERDICT & FIX PLAN

Final Assessment

Login Flow is a **B+ grade feature**. The form has accessible error feedback (`role=alert`, `aria-invalid`, `aria-describedby`), password-manager-friendly attributes, working Enter-key submission, proper redirect-after-login, and correct mobile handling. Four gaps: no rate limiting (4 hours), missing enterkeyhint (5 min), robots should be `noindex` (5 min), and no already-authed redirect (30 min). The accessible error handling is the standout — AAA-level WCAG compliance.

5.1 Phased Fix Plan

PHASE	FIXES	EFFORT	OUTCOME
Phase 1 · Now (Today)	Gaps #2 (enterkeyhint) + #3 (noindex) + aria-pressed on toggle	~20 minutes	Grade lifts to A-. Mobile UX + SEO + a11y fixes.
Phase 2 · Next (This week)	Gap #1 (rate limiting) + Gap #4 (already-authed redirect)	~5 hours	Grade lifts to A. Defense-in-depth + UX.

5.2 Cross-Feature Dependencies

- ✓ Feature #8 (Auth Model) — the login flow is the input layer for #8's auth system; #8 covers the broader security model
- ✓ Feature #9 (Session Management) — the login flow creates the session that #9 manages
- ✓ Feature #61 (Live Regions) — the role=alert error region is the one live region DzPharm correctly implements (covered in #61)
- ✓ Feature #63 (Skip Link & Landmarks) — the login page has the skip-link and region landmarks covered in #63

5.3 Final Assessment

8 TESTS PASSED	4 GAPS	Pass WCAG 3.3.1
B+ GRADE	~20m PHASE 1 EFFORT	~5h PHASE 2 EFFORT

FINAL VERDICT · B+ GRADE, 20 MINUTES FROM A-

Login Flow is a **B+ grade feature** — better than the earlier #8 report suggested. The form has accessible error feedback (role=alert + aria-live=assertive + aria-invalid + aria-describedby — AAA-level WCAG 3.3.1 compliance). Password-manager detection works (type, autocomplete, label, id). Enter key submits. Redirect-after-login preserves destination. Mobile is well-handled (48px input, 16px button font). Four gaps: no rate limiting (4 hours — defense-in-depth), missing enterkeyhint (5 min — mobile UX), robots should be noindex (5 min — SEO/security), and no already-authed redirect (30 min — UX). Phase 1 (20 minutes — enterkeyhint + noindex + aria-pressed) lifts to A-. Phase 2 (5 hours — rate limiting + redirect) lifts to A. The accessible error handling is the standout — it's the one place where DzPharm's a11y is textbook (the same role=alert pattern is missing from the Copilot and toasts, covered in #61).

Immediate Next Steps

1. Add `enterkeyhint="go"` to the password input — 5 minutes.
2. Change robots meta to `noindex, nofollow` — 5 minutes.
3. Add `aria-pressed` to the show/hide toggle — 10 minutes.
4. Add already-authenticated redirect (`/login → /`) — 30 minutes.
5. Defer rate limiting (Phase 2 — needs server-side Redis or similar).

7

Accessible errors (AAA), password-manager friendly, mobile-correct. 4 gaps (rate limit, enterkeyhint, noindex, redirect). 20 min lifts to A-.

5

CHAPTERS

6

SCREENSHOTS

8

TESTS PASSED

B+

GRADE